

MMD V2 - Role Permission Matrix

1. Overview

The platform follows Role Based Access Control (RBAC).

Permissions are assigned to Roles.

Users receive permissions through assigned roles.

Every permission follows:

MODULE.ACTION

Example:

companies.create companies.read companies.update companies.delete

2. Role Hierarchy

SUPER_ADMIN

↓

TENANT_OWNER

↓

ADMIN

↓

MANAGER

↓

RECRUITER

↓

SCRAPER

↓

VIEWER

3. SUPER_ADMIN

Purpose:

Platform Owner

Scope:

Entire SaaS Platform

Permissions:

- Full Access
- Create Tenants
- Delete Tenants
- Manage Plans
- Manage Billing
- View All Data
- System Settings
- Feature Flags
- Global Reports
- Audit Logs

Restrictions:

None

4. TENANT_OWNER

Purpose:

Owner of Customer Organization

Scope:

Own Tenant Only

Permissions:

- Manage Company Users
- Manage Branding
- Manage Subscription
- Manage Roles
- View Reports
- Manage Workflows
- Manage Integrations

Restrictions:

Cannot access other tenants.

5. ADMIN

Purpose:

Organization Administrator

Scope:

Organization Operations

Permissions:

Users

- users.create
- users.read
- users.update
- users.disable

Companies

- companies.create
- companies.read
- companies.update

Contacts

- contacts.create
- contacts.read
- contacts.update

Leads

- leads.create
- leads.read
- leads.update
- leads.assign

Requirements

- requirements.create
- requirements.read
- requirements.update

Candidates

- candidates.create
- candidates.read
- candidates.update

Placements

- placements.create
- placements.read
- placements.update

Reports

- reports.read

Restrictions:

Cannot manage billing.

Cannot access platform settings.

6. MANAGER

Purpose:

Team Manager

Scope:

Assigned Team

Permissions:

Users

- users.read

Leads

- leads.read
- leads.assign

Requirements

- requirements.read
- requirements.assign

Candidates

- candidates.read

Placements

- placements.read

Reports

- reports.read

Restrictions:

Cannot create users.

Cannot delete records.

Cannot access tenant settings.

7. RECRUITER

Purpose:

Recruitment Operations

Permissions:

Requirements

- requirements.read

Candidates

- candidates.create
- candidates.read
- candidates.update

Applications

- applications.create
- applications.read
- applications.update

Interviews

- interviews.create
- interviews.read
- interviews.update

Placements

- placements.read

Reports

- reports.read_own

Restrictions:

Only assigned records.

Cannot view financial data.

8. SCRAPER

Purpose:

Lead Collection

Permissions:

Companies

- companies.create
- companies.read

Contacts

- contacts.create
- contacts.read

Leads

- leads.create
- leads.read

Restrictions:

Cannot access ATS.

Cannot access reports.

Cannot access invoices.

Cannot access placements.

9. VIEWER

Purpose:

Read Only User

Permissions:

- companies.read
- contacts.read
- leads.read
- candidates.read
- requirements.read
- reports.read

Restrictions:

No create.

No update.

No delete.

10. Permission Categories

User Permissions

users.create users.read users.update users.delete users.disable

Company Permissions

companies.create companies.read companies.update companies.delete

Contact Permissions

contacts.create contacts.read contacts.update contacts.delete

Lead Permissions

leads.create leads.read leads.update leads.delete leads.assign leads.convert

Requirement Permissions

requirements.create requirements.read requirements.update requirements.delete requirements.assign requirements.close

Candidate Permissions

candidates.create candidates.read candidates.update candidates.delete

Application Permissions

applications.create applications.read applications.update applications.delete

Interview Permissions

interviews.create interviews.read interviews.update interviews.cancel

Placement Permissions

placements.create placements.read placements.update placements.delete

Timesheet Permissions

timesheets.create timesheets.read timesheets.update timesheets.approve

Invoice Permissions

invoices.create invoices.read invoices.update invoices.send

Template Permissions

templates.create templates.read templates.update templates.delete

Workflow Permissions

workflows.create workflows.read workflows.update workflows.delete

Reports Permissions

reports.read reports.export

Webhook Permissions

webhooks.create webhooks.read webhooks.update webhooks.delete

API Key Permissions

api_keys.create api_keys.read api_keys.delete

11. Row Level Security Rules

All records contain:

tenantId

Users can only access:

`records.tenantId == user.tenantId`

Additional Restrictions:

Recruiter:

Only assigned records.

Manager:

Assigned team records.

Admin:

Entire tenant.

Super Admin:

Entire platform.

12. UI Visibility Rules

Hide menu items without permission.

Hide buttons without permission.

Hide reports without permission.

Hide pages without permission.

Never rely on frontend only.

Backend validation mandatory.

13. API Security Rules

Every API must verify:

1. Authentication
2. Tenant
3. Role
4. Permission

Example:

companies.create

Before allowing:

POST /api/companies

14. Future Permission Expansion

Future:

custom roles

custom permissions

department permissions

record ownership

field-level permissions

approval workflows